

面向 ML-KEM 解封装实现的 时间侧信道泄漏检测研究

课 程 名 称：量子计算与后量子密码

学 生 姓 名：寇得一

学 号：2023211545

学 院：网络空间安全学院

专 业：信息安全

指 导 教 师：窦钊

2026 年 5 月

摘 要

随着后量子密码标准化推进, ML-KEM 已成为密钥封装机制的重要部署对象。然而, 算法层面的标准化并不等同于具体软件实现的侧信道安全。本文面向 pqcrypto 库中的 ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 解封装实现, 构建了一套基于统计检验与机器学习的软件时间侧信道泄漏筛查流程。实验比较有效密文与四类同长度无效密文输入, 提取 13 维时间统计特征, 并结合 Welch's t 检验、KS 检验、Cohen's d 、逻辑回归、线性 SVM、随机森林和梯度提升树进行多证据判定。

在 5 轮独立重复、3 个参数集和 4 种无效密文策略构成的 60 次完整实验中, 固定延迟正对照均能被稳定识别, 说明检测管线具备识别已知时间信号的能力; 真实场景下最佳模型平衡准确率均值为 0.5134, 60 次实验均未触发泄漏判定。结果表明, 在本文的软件计时条件、输入模型和被测实现版本下, 未检测到 ML-KEM 解封装过程对有效密文与无效密文表现出稳定、可区分的时间侧信道泄漏。该结论属于实现级筛查结论, 不构成形式化侧信道安全证明。

关键词: 后量子密码; ML-KEM; 时间侧信道; 机器学习; 泄漏检测

目录

1	引言	1
1.1	研究背景	1
1.2	研究目的与问题提出	1
1.3	主要贡献	2
2	相关工作	2
2.1	时间侧信道与实现安全	2
2.2	格基 KEM 的侧信道研究	3
2.3	机器学习辅助泄漏检测	3
3	理论基础	3
3.1	ML-KEM 参数集	3
3.2	统计检验与效应量	4
3.3	分组机器学习评估	4
4	实验设计与实现	6
4.1	总体技术路线	6
4.2	威胁模型与观测模型	6
4.3	实验对象与运行环境	7
4.4	无效密文策略	7
4.5	采集流程	8
4.6	特征与判定规则	8
5	实验结果	9
5.1	数据完整性与总体概况	9
5.2	时间分布	9
5.3	跨参数集与策略的统计结果	10
5.4	机器学习分类结果	10
5.5	延迟灵敏度扫描	11
5.6	特征重要性与运行稳定性	13
6	讨论	15
6.1	结果解释	15
6.2	实验局限性	15
6.3	可复现性与后续工作	16
7	结论	16
	参考文献	18

1 引言

1.1 研究背景

公钥密码体制是现代网络安全基础设施的核心组成部分，广泛用于密钥协商、身份认证、软件签名和安全通信协议。RSA、Diffie-Hellman 和椭圆曲线密码等经典方案的安全性主要建立在大整数分解和离散对数问题的计算困难性之上。Shor 在 1994 年提出的量子算法表明，具备足够规模和纠错能力的量子计算机能够在多项式时间内求解这两类问题 [17]。因此，即便大规模通用量子计算机尚未实用化，密码系统也需要提前迁移到能够抵抗量子攻击的后量子密码算法。

NIST 自 2016 年启动后量子密码标准化进程，并于 2024 年发布首批后量子密码标准。其中 FIPS 203 将 CRYSTALS-Kyber 标准化为 Module-Lattice-Based Key-Encapsulation Mechanism，即 ML-KEM [1, 13]。ML-KEM 基于模格误差学习 (Module Learning With Errors, MLWE) 问题，提供 ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 三组参数，分别对应不同安全级别和性能开销。

然而，算法标准解决的是规范层面的安全问题，并不能自动保证具体实现没有侧信道泄漏。Kocher 的时序攻击工作最早系统性说明了公钥密码操作的执行时间可能泄露私钥信息 [10]；Bernstein 随后展示了缓存状态也可能形成可利用的时间差异 [3]。对于后量子 KEM 而言，解封装阶段同时接收攻击者可控密文并使用私钥，是实现安全分析中的重点环节。已有研究表明，CCA 安全格基 KEM 中的 Fujisaki-Okamoto 变换和重加密验证步骤可能成为功耗或电磁侧信道分析的重要目标 [16, 18]。因此，对 ML-KEM 实现开展可复现的泄漏检测具有直接的工程意义。

1.2 研究目的与问题提出

本文的研究目的，是面向 ML-KEM 解封装这一实现安全敏感环节，建立一套可复现、可量化、可解释的软件时间侧信道泄漏筛查方法。本文不以构造完整密钥恢复攻击为目标，也不试图证明某一实现具备形式化侧信道安全性，而是关注攻击者可控密文输入是否会使解封装过程表现出稳定、可检测、可进一步分析的执行时间差异。

围绕上述目的，本文主要回答以下研究问题：

- RQ1** 在 pqcrypto 库提供的 ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 解封装实现中，有效密文与无效密文之间是否存在可由统计检验识别的执行时间差异？
- RQ2** 在多维时间统计特征下，机器学习分类器能否在未见过的基础密文组上稳定区分有效密文与无效密文？
- RQ3** 不同参数集和不同无效密文构造策略是否会改变泄漏检测结果？
- RQ4** 在软件计时噪声存在的条件下，本文检测管线能否识别已知人为时间信号，其灵敏度边界大致处于什么量级？

通过上述问题，本文希望给出一个边界清晰的实现级判断：若检测到稳定信号，则说明被测实现需要进一步侧信道审计；若未检测到稳定信号，则只能说明在本文平

台、输入模型和计时方法下没有发现可区分泄漏，而不能推出算法或实现的绝对侧信道安全。

上述问题的提出基于两个事实。第一，ML-KEM 已进入标准化和部署阶段，FIPS 203 对算法接口、参数和正确性给出规范，但实现仍需接受独立的侧信道评估 [13]。第二，传统测试向量泄漏评估（TVLA）强调通过统计检验发现两类输入之间的泄漏信号 [2]，而机器学习分类器能够从多维特征组合中发现非线性或非均值差异。因此，本文将参数检验、非参数检验、效应量和机器学习判别能力结合起来，形成多证据交叉验证的实现级检测方法。

1.3 主要贡献

本文的主要贡献如下：

1. 面向 ML-KEM 解封装实现，构建了一套可复现的软件时间侧信道泄漏筛查框架，覆盖 ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 三个参数集，并支持多轮重复实验与自动化结果分析。
2. 设计了四类同长度无效密文输入模型，包括单比特扰动、字节翻转、伪随机密文和全零密文，用于从最小扰动、局部破坏、随机无效输入和极端结构化输入等角度考察解封装时间行为。
3. 结合统计显著性、效应量和机器学习可分性建立多证据泄漏判定方法，并通过分组交叉验证降低同一基础密文组带来的记忆性数据泄漏风险。
4. 引入固定延迟正对照和延迟灵敏度扫描，验证检测管线对已知时间信号的识别能力，从而提高负检测结论的可信度。
5. 基于 5 轮独立重复、3 个参数集和 4 种无效密文策略的 60 次完整实验，给出被测 pqcrypto ML-KEM 解封装实现的软件时间泄漏筛查结果，并明确说明该结果的适用边界。

2 相关工作

2.1 时间侧信道与实现安全

时间侧信道攻击的核心思想是通过观测程序运行时间推断秘密相关信息。Kocher 证明了不同私钥比特引发的模幂运算路径差异可以通过大量计时观测恢复 [10]。后续远程计时研究进一步说明，即使通过网络进行测量，时序差异仍可能在现实环境下被利用 [6]。Bernstein 对 AES 的缓存时序攻击则表明，侧信道并不只来自显式分支，内存访问和缓存命中状态同样可能泄露信息 [3]。

这些研究推动了常数时间编程和实现级安全评估的发展。对于后量子密码算法，虽然其数学困难性不同于 RSA 和椭圆曲线密码，但底层软件仍运行在相同的处理器、缓存和操作系统之上，因此同样需要关注输入相关的执行时间差异。因此，本文将执行时间作为可观测信道，关注攻击者可控输入是否会在 ML-KEM 解封装实现中诱发稳定的时间差异。

2.2 格基 KEM 的侧信道研究

CRYSTALS-Kyber/ML-KEM 属于格基 KEM，其解封装过程包含解密、重加密、密文比较和失败路径密钥派生等步骤。Ravi 等人从通用角度研究了 CCA 安全格基 PKE/KEM 的侧信道问题，指出若实现泄露解封装成功与失败路径差异，可能为选择密文攻击提供入口 [16]。Ueno 等人提出“重加密诅咒”，展示 FO 变换中的重加密步骤在功耗与电磁信道下具有泛化的攻击面 [18]。Primas 等人则从单轨迹功耗分析角度说明，即便格密码实现采用一定防护，细粒度实现特征仍可能被分析利用 [15]。

与功耗和电磁分析相比，软件计时实验的攻击门槛更低，但信噪比也更差，因此本文将其实定位为早期筛查方法，而非完整攻击方法。检测到信号说明实现值得进一步审计；未检测到信号则只能说明当前条件下未发现可区分差异。

值得特别关注的是，KyberSlash 工作报告了 Kyber/ML-KEM 多个实现（包括参考实现）中确实存在的密钥相关时序泄漏：在 `poly_tomsg` 等模块化压缩步骤中，对模数 q 的变长除法运算耗时与中间值相关，攻击者可在 Cortex-A7 和 Cortex-M4 等平台上通过该时序差异在数分钟到数小时内恢复密钥 [4]。这一案例表明，ML-KEM 的时间侧信道泄漏并非纯理论假设，而是已在真实实现中被发现并修复的问题。该工作同时提出基于 Valgrind 的指令级污点分析方法，用于在源码层面定位变长时间操作。本文与之的主要区别在于观测粒度：KyberSlash 类工作针对单条指令或单个算术运算的执行时间，而本文从输入（有效/无效密文）到端到端解封装耗时这一更粗粒度的黑盒视角出发，因此二者在检测能力和适用阶段上是互补的。

2.3 机器学习辅助泄漏检测

机器学习方法已广泛用于侧信道分析中的模板攻击和特征识别。Lerman 等人比较了随机森林、支持向量机和 k 近邻等模型在功耗分析中的表现 [11]；Cagli 等人将卷积神经网络用于带有抖动对抗措施的功耗轨迹，展示了深度学习方法对复杂轨迹错位的适应能力 [7]。但深度模型通常需要大量轨迹和更高训练成本，且可解释性较弱。

本文面向小样本、白盒、筛查型的软件计时任务，因此选择逻辑回归、线性 SVM、随机森林和直方图梯度提升树作为检测模型。这些模型既能覆盖线性与非线性判别，又便于与统计检验、置换检验和特征重要性分析结合。本文将机器学习分类结果作为统计检验之外的补充证据，而不是以模型准确率替代传统泄漏评估。

3 理论基础

3.1 ML-KEM 参数集

ML-KEM 是一种密钥封装机制，包含密钥生成、封装和解封装三个接口。其安全性基于模格误差学习问题，底层多项式环通常记为 $R_q = \mathbb{Z}_q[X]/(X^{256} + 1)$ ，其中 $q = 3329$ 。三个参数集的主要差异在于模块维度 k 和压缩参数，进而影响公钥、密文、私钥大小和计算开销。表 1 列出 FIPS 203 中与本文实验相关的主要参数 [13]。

表 1: ML-KEM 三个参数集的接口规模

参数集	NIST 安全级别	公钥大小 (B)	密文大小 (B)	私钥大小 (B)
ML-KEM-512	1	800	768	1632
ML-KEM-768	3	1184	1088	2400
ML-KEM-1024	5	1568	1568	3168

本文重点测量解封装阶段。该阶段输入私钥和外部密文，输出共享密钥。若密文验证失败，实现应返回由私钥中随机种子和输入密文派生的伪随机值，而不是泄露失败路径的内部状态。理想情况下，有效密文和无效密文不应在可观测时间上形成稳定差异。

3.2 统计检验与效应量

设有效密文样本的聚合均值为 $\{x_i\}_{i=1}^{n_0}$ ，无效密文样本为 $\{y_i\}_{i=1}^{n_1}$ 。Welch's t 检验用于判断两组均值是否存在显著差异，且不要求两组方差相等 [19]:

$$t_W = \frac{\bar{x} - \bar{y}}{\sqrt{s_x^2/n_0 + s_y^2/n_1}}. \quad (1)$$

在本文中，Welch's t 检验主要用于判断两类输入的平均解封装时间是否存在显著差异。Mann-Whitney U 检验不依赖正态分布假设，更适合长尾计时数据 [12]。KS 检验比较两组经验分布函数的最大距离，可检测均值之外的整体分布形状变化。Cohen's d 用于衡量差异的实践大小 [9]:

$$d = \frac{\bar{y} - \bar{x}}{\sqrt{(s_x^2 + s_y^2)/2}}. \quad (2)$$

其中，KS 检验用于判断两类时间分布整体形态是否不同；Cohen's d 用于判断差异是否具有实际效应，而不只是统计显著。本文将 $p < 0.01$ 作为主要统计显著性阈值，将 $|d| \geq 0.2$ 作为可解释效应的最低阈值。

3.3 分组机器学习评估

在分类检测中，特征向量由每条聚合轨迹的 13 维统计量构成，标签表示有效密文或无效密文。本文使用平衡准确率作为主要指标:

$$\text{BalAcc} = \frac{1}{2} \left(\frac{TP}{TP + FN} + \frac{TN}{TN + FP} \right). \quad (3)$$

在本文中，平衡准确率用于衡量模型对有效密文和无效密文的泛化区分能力。两类样本数量相等时，随机猜测的期望平衡准确率为 0.5。为避免模型记住同一基础密文组的偶然计时特征，本文使用 GroupShuffleSplit，要求同一 group_id 下的有效样本

和无效样本始终同时位于训练集或测试集一侧。随机森林使用 Breiman 的集成树模型 [5], 梯度提升树参考提升树的逐步残差拟合思想 [8], 模型实现基于 scikit-learn [14]。

4 实验设计与实现

4.1 总体技术路线

本文的检测流程由输入构造、计时采集、特征提取、统计检验、机器学习评估和泄漏判定六个部分组成。整体架构如图 1 所示：首先针对三个 ML-KEM 参数集生成有效密文，并按照四种策略构造同长度无效密文；随后在真实场景和固定延迟正对照场景下采集解封装时间；最后将原始计时聚合为统计特征，并用多种统计检验和分类模型交叉判断是否存在稳定可区分的时间差异。



图 1: ML-KEM 解封装时间侧信道泄漏检测整体架构

4.2 威胁模型与观测模型

本文考虑的攻击者是与被测程序运行在同一台机器上的本地、协同驻留进程。该攻击者具备选择密文能力：可以构造任意同长度密文并提交给目标实现的解封装接口，但不能访问私钥或其内部状态，目标与 CCA 安全模型中的攻击者一致。攻击者通过被测进程自身提供的高精度计时接口 (Python `time.perf_counter_ns`) 获取每次解封装调用的墙钟时间，不依赖缓存探测、性能计数器或功耗/电磁探针等更强的旁路观测手段。

观测模型上，本文不直接使用单次调用的原始计时，而是将连续 $R = 50$ 次解封装的耗时聚合为均值等 13 维统计特征，再据此判断有效密文与无效密文是否可区分。这一设置对应攻击者可以多次重放同一密文并进行统计平均的场景，但不对应一次性观测、网络传输延迟主导或攻击者只能获得粗粒度计时（如毫秒级）的更弱场景——在后两种场景下，本文方法提供的灵敏度上界会进一步劣化。本文的判定结论应在该观测模型下理解：若在本地、可重复采样、纳秒级精度的有利条件下仍未检测到

稳定差异，则在更弱的观测条件（如 Brumley 和 Boneh 讨论的远程网络计时 [6]）下检测到差异的可能性只会更低，而不会更高。

4.3 实验对象与运行环境

本文实验对象为 Python pqcrypto==0.3.4 包提供的 ML-KEM 三个参数集绑定 (512、768 和 1024)。正式论文数据来自 Windows 11 x86_64 平台，软件环境如表 2 所示。

表 2: 正式实验运行环境

项目	配置
CPU	Intel Core i7-12700K（支持 AVX2）
操作系统	Windows 11 x86_64 (10.0.26200)
Python	3.12.12（Anaconda 发行版）
ML-KEM 实现	ml_kem_512/768/1024
pqcrypto	0.3.4
numpy	2.0.2
scipy	1.13.1
scikit-learn	1.6.1
matplotlib	3.9.4

4.4 无效密文策略

每个基础密文组首先通过封装得到一个有效密文，然后构造同长度的无效密文。本文使用四种策略，见表 3。这四类策略覆盖了从接近合法密文到完全非结构化输入的不同扰动强度：single_bit 和 byte_flip 用于观察局部扰动是否触发解封装路径差异；random_bytes 用于模拟一般随机无效密文；zero 则用于测试极端结构化输入是否造成异常时间行为。

表 3: 无效密文构造策略

策略	构造方式	目的
single_bit	基于 SHA-256 派生字节位置和比特位，仅翻转一位	最小扰动输入
byte_flip	基于 SHA-256 派生字节位置，并将该字节异或 0xFF	中等局部扰动
random_bytes	生成同长度确定性伪随机字节串	模拟随机无效密文
zero	生成同长度全零密文	模拟结构化极端输入

所有策略均保持密文长度不变，以避免将长度错误引起的异常处理路径混入主

要实验信号。对于 `single_bit` 策略，扰动位置由

$$h = \text{SHA256}(\text{LE32}(g)), \quad \text{idx} = \text{int}(h_0, \dots, h_3) \bmod |\text{ct}|, \quad \text{bit} = h_4 \bmod 8 \quad (4)$$

确定，其中 g 为基础密文组编号。

4.5 采集流程

每次实验首先生成一个 ML-KEM 密钥对，并生成 60 个基础有效密文组。正式采集前执行 500 次解封装预热，预热过程在有效密文和无效密文之间交替，以减少某一类样本获得更热缓存状态的系统偏差。随后为每类构造 400 条聚合采集任务，随机打乱后逐条执行。每条聚合轨迹重复执行 50 次解封装，并记录纳秒级原始时间。整体流程如算法 1 所示。

算法 1 ML-KEM 解封装时间采集流程

输入：参数集 v ，无效密文策略 s ，组数 $G = 60$ ，每类样本数 $N = 400$ ，重复次数 $R = 50$

输出：真实场景与正对照场景下的特征表和分析报告

```

1:  $(pk, sk) \leftarrow \text{KeyGen}_v()$ 
2: for  $g = 0$  to  $G - 1$  do
3:    $(ct_g, K_g) \leftarrow \text{Encaps}_v(pk)$ 
4:    $\tilde{ct}_g \leftarrow \text{Invalid}(ct_g, g, s)$ 
5: end for
6: 交替执行 500 次  $\text{Decaps}_v(sk, ct_g)$  与  $\text{Decaps}_v(sk, \tilde{ct}_g)$ 
7: 构造有效/无效两类采集任务并随机打乱
8: for 每个采集任务  $(g, label, ct)$  do
9:   重复执行  $R$  次解封装计时
10:  从 50 个原始时间提取 13 维统计特征
11: end for
12: 对真实场景和 20,000 ns 正对照分别执行统计检验与模型评估

```

4.6 特征与判定规则

对每条聚合轨迹提取的 13 维特征包括：均值、中位数、标准差、最小值、最大值、第 10 百分位数、第 90 百分位数、四分位距、中位绝对偏差、5% 截尾均值、偏度、超额峰度和变异系数。线性模型使用 `RobustScaler` 做稳健缩放并裁剪极端值；树模型直接使用原始特征。

软件计时数据容易受到操作系统调度、缓存状态、动态频率和后台进程影响，单一统计量可能出现偶然显著。因此，本文不将某一个 p 值或某一次分类准确率作为泄漏证据，而采用分类可分性、统计显著性和效应量共同满足的联合判定规则。该设计用于降低误报风险，使泄漏判定更偏向保守。

真实场景仅当以下条件全部成立时报告检测到泄漏：最佳模型平衡准确率不低于 0.65，Welch's t 检验 $p < 0.01$ ，且 $|d| \geq 0.2$ 。正对照要求最佳模型平衡准确率不低

于 0.90，且 Welch's t 检验 $p < 0.001$ 。这一区分保证了真实场景判断不会只依赖单一统计量，同时正对照用于确认管线确实能识别已知时间信号。

5 实验结果

5.1 数据完整性与总体概况

正式实验覆盖 5 轮独立重复、3 个参数集和 4 种无效密文策略，共 $5 \times 3 \times 4 = 60$ 次完整实验。每次实验包含真实场景和正对照场景，每个场景两类标签各 400 条聚合样本，因此共有 96,000 条聚合样本；每条样本包含 50 次重复计时，对应约 480 万次原始解封装计时。数据质量报告显示：60 次实验均完成，标签平衡、缺失值、非有限数值和重复 `trace_id` 检查均通过；所有正对照管线均有效。

跨 60 次真实场景实验，扰动密文相对有效密文的平均时间差均值为 81.6 ns，标准差为 1044.9 ns，最小值和最大值分别为 -1691.5 ns 与 2014.8 ns。最佳真实模型平衡准确率均值为 0.5134，范围为 0.4761–0.5566；正对照最佳模型平衡准确率均值为 0.9995。

5.2 时间分布

图 2 给出所有参数集与策略汇总后的真实场景和正对照时间分布。真实场景中，两类样本的主体分布高度重叠，未出现稳定可见的分离；正对照中，无效密文类因额外 20,000 ns 忙等待延迟整体右移，分布差异清晰，说明计时和分析流程能够捕获已知信号。

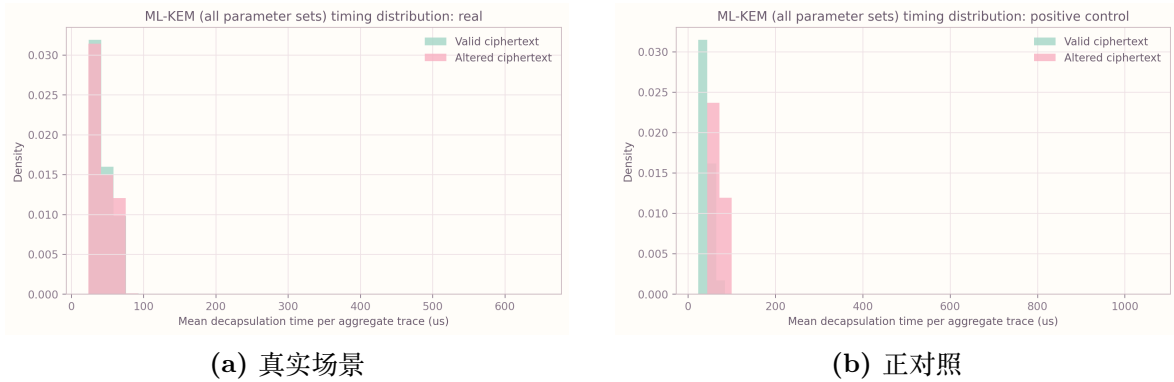


图 2: 所有参数集与无效密文策略汇总后的解封装平均时间分布。

进一步地，图 3 展示了 `single_bit` 策略下三个参数集在 5 轮真实实验中的时间分布。随着参数集从 512 增大到 1024，平均解封装时间整体上升；但在每个参数集中，有效密文和单比特扰动密文的分布仍然高度重叠。

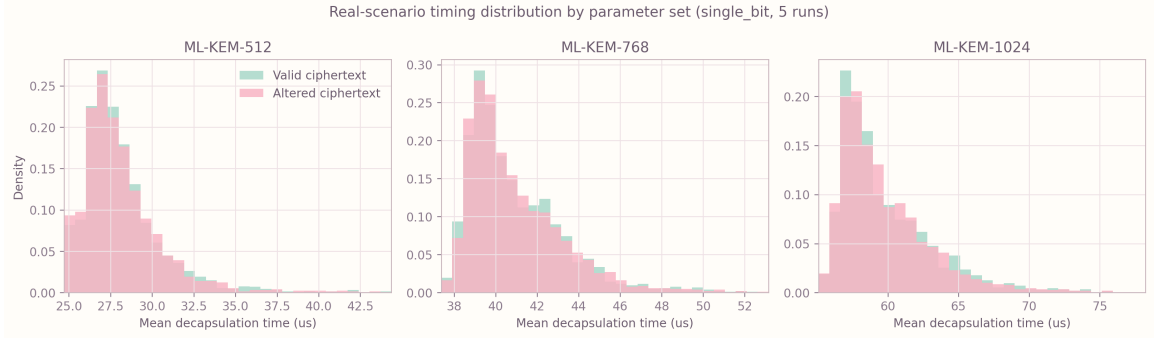


图 3: `single_bit` 策略下三个参数集的真实场景时间分布（5 轮合并）。

5.3 跨参数集与策略的统计结果

表 4 汇总了 12 个参数集/策略组合在 5 轮真实实验中的均值结果。所有组合均未触发泄漏判定；Welch’s t 检验 5 轮均值均远高于 0.01；KS 检验均值也未形成稳定显著模式；Cohen’s d 的组合均值绝对值最高仅为 0.0448，低于可忽略效应阈值 0.2。

由于本文在 12 个参数集/策略组合上重复进行假设检验，单一组合的 $p < 0.01$ 判定还需考虑多重比较带来的族系错误率（family-wise error rate）膨胀问题。按 Holm-Bonferroni 方法，在族系显著性水平 0.01、共 12 次比较的条件下，最严格的单次比较阈值约为 $0.01/12 \approx 8.3 \times 10^{-4}$ 。表 4 中最小的 Welch’s t 检验均值为 0.262（1024、zero），仍比该阈值大两个数量级以上。因此，即使不做多重比较校正，本文也未在任一组合上观察到接近显著的结果；引入校正只会使各组合更难被判定为显著，不改变“未检测到泄漏”的结论，但能排除多重检验导致的假阳性风险。

表 4: 12 个参数集/策略组合的真实场景与正对照结果（5 轮均值）

参数集	策略	$\Delta\mu$ ns	Welch p	KS p	Cohen’s d	真实最佳准确率	正对照最佳准确率
512	<code>single_bit</code>	-31.2	0.275	0.438	-0.0031	0.515	1.000
512	<code>byte_flip</code>	-83.1	0.284	0.383	0.0253	0.517	1.000
512	<code>random_bytes</code>	-210.8	0.428	0.475	-0.0075	0.506	1.000
512	<code>zero</code>	988.6	0.327	0.561	0.0447	0.528	1.000
768	<code>single_bit</code>	-780.4	0.284	0.695	-0.0448	0.505	1.000
768	<code>byte_flip</code>	636.8	0.416	0.436	0.0224	0.510	1.000
768	<code>random_bytes</code>	177.6	0.608	0.531	-0.0020	0.511	1.000
768	<code>zero</code>	-225.9	0.333	0.722	-0.0118	0.505	0.999
1024	<code>single_bit</code>	6.1	0.441	0.372	-0.0022	0.522	0.998
1024	<code>byte_flip</code>	720.2	0.578	0.516	0.0350	0.506	0.999
1024	<code>random_bytes</code>	397.0	0.357	0.558	0.0076	0.513	1.000
1024	<code>zero</code>	-616.3	0.262	0.493	-0.0442	0.523	0.999

5.4 机器学习分类结果

表 5 汇总了 60 次实验中四种分类器的平均表现。在标签均衡的二分类任务中，平衡准确率 0.5 对应随机猜测水平。如果模型在分组交叉验证下长期接近 0.5，说明其无法在未见过的基础密文组上学习到稳定的有效/无效密文区分边界。真实场景下所有模型的平衡准确率均接近 0.5，正对照中四种模型则接近完美分类，进一步验证检测管线有效。

表 5: 四种模型跨 60 次实验的平均平衡准确率

模型	真实场景均值	真实场景标准差	正对照均值	正对照标准差
逻辑回归	0.4996	0.0190	0.9987	0.0016
线性 SVM	0.4986	0.0152	0.9989	0.0014
随机森林	0.4976	0.0198	0.9993	0.0011
梯度提升树	0.4961	0.0188	0.9989	0.0017

图 4 从参数集和无效密文策略两个维度展示最佳模型平衡准确率。真实场景柱形图始终贴近随机基线 0.5，而正对照均接近 1.0。这表明不同安全级别和不同无效密文构造方式没有改变总体结论。

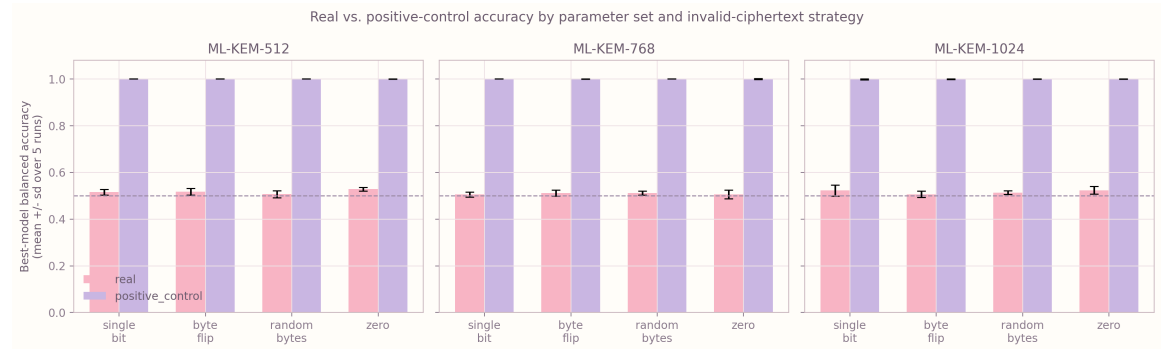


图 4: 各参数集和无效密文策略下真实场景与正对照的最佳模型平衡准确率。

5.5 延迟灵敏度扫描

为理解检测管线的灵敏度，本文对 ML-KEM-768 与 `single_bit` 策略执行额外的正对照延迟扫描，延迟档位为 500、1,000、2,000、5,000、10,000 和 20,000 ns。结果见表 6 和图 5。500 ns 时，KS 检验已经检测到分布形态变化，但均值检验和效应量尚未达到泄漏判定阈值；5,000 ns 时，最佳模型准确率、Welch 检验和效应量首次同时满足真实场景三条件判定规则；10,000 ns 以后，正对照信号非常稳定。

表 6: ML-KEM-768 / `single_bit` 延迟灵敏度扫描

延迟 (ns)	最佳平衡准确率	Welch p	KS p	Cohen's d
500	0.633	1.16×10^{-1}	3.25×10^{-4}	0.112
1000	0.634	7.31×10^{-1}	6.92×10^{-5}	-0.024
2000	0.738	6.09×10^{-2}	2.63×10^{-10}	0.133
5000	0.885	1.94×10^{-45}	1.88×10^{-61}	1.067
10000	0.985	2.20×10^{-97}	5.46×10^{-141}	1.716
20000	0.998	$< 10^{-300}$	3.40×10^{-234}	5.548

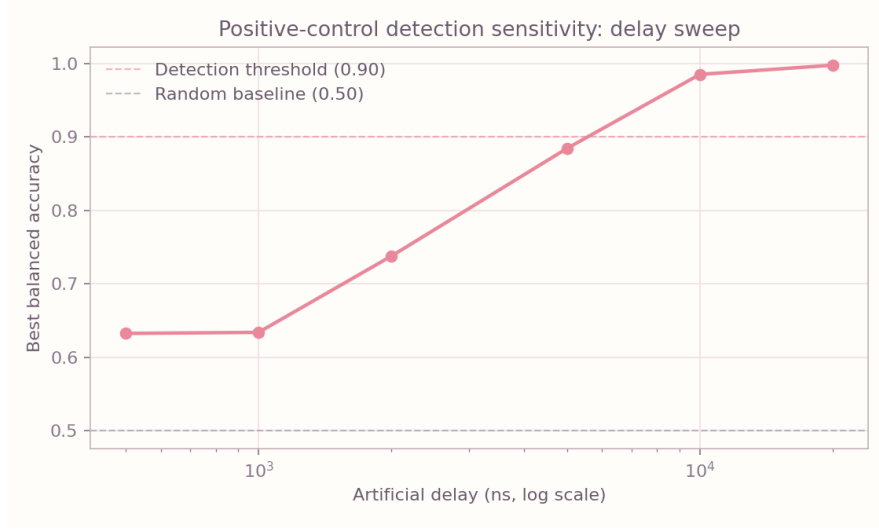


图 5: 正对照延迟扫描中最佳模型平衡准确率随人为延迟的变化。

为将上述经验观察转化为可量化的检测下界, 本文基于两样本 t 检验的功效近似公式估计本文实验设计下的最小可检测效应量 [9]:

$$d_{\min} \approx (z_{\alpha/2} + z_{\beta}) \sqrt{2/n}. \quad (5)$$

在本文 $\alpha = 0.01$ (双侧, $z_{\alpha/2} \approx 2.576$)、每类 $n = 400$ 的设置下, 若取检验功效 $1 - \beta = 0.80$ ($z_{\beta} \approx 0.842$), 则 $d_{\min} \approx 0.242$; 本文判定规则采用的效应量阈值 $|d| \geq 0.2$ 在该样本量下对应的功效约为 60%, 略低于 80% 这一常用标准。

将 $d_{\min}$ 换算为绝对时间需要每类聚合轨迹均值 (mean_ns) 的合并标准差。本文对 60 次真实场景实验的原始数据按参数集计算合并标准差, 并据此给出两个效应量阈值对应的最小可检测时间差异, 结果见表 7。

表 7: 各参数集的合并标准差与最小可检测效应 (MDE)

参数集	合并标准差 (μs)	MDE @ $ d = 0.2$ (μs , 约 60% 功效)	MDE @ 80% 功效 (μs , $d \approx 0.242$)
ML-KEM-512	9.9	2.0	2.4
ML-KEM-768	14.3	2.9	3.5
ML-KEM-1024	12.8	2.6	3.1

表 7 中 80% 功效对应的最小可检测效应 (2.4–3.5 μs , 视参数集而定) 与表 6 的延迟扫描结果吻合: 2,000 ns 的人为延迟 ($d = 0.133$) 低于该下界, 三条件判定规则未被触发; 5,000 ns ($d = 1.067$) 已远高于下界, 规则首次被全部满足。图 6 在延迟扫描曲线上叠加了 ML-KEM-768 的 MDE 区间 (对应表 7 中 $|d| = 0.2$ 到 $d \approx 0.242$ 的 2.9–3.5 μs), 可以看到该区间正好落在曲线由“未达检测阈值”向“稳定检测”过渡的拐点附近, 与理论估计一致。

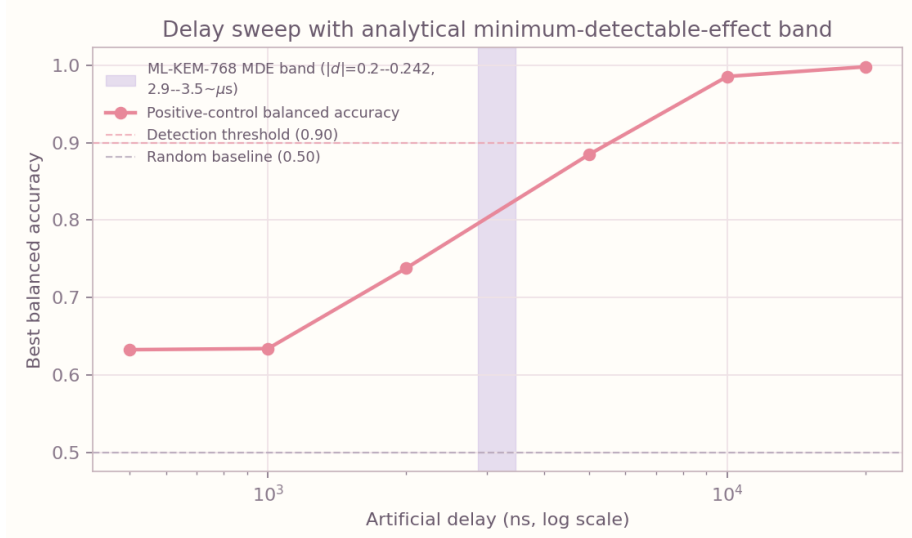


图 6: 延迟扫描曲线与 ML-KEM-768 最小可检测效应 (MDE) 区间的叠加。

因此, 本文真实场景”未检测到泄漏”的结论可更精确地表述为: 在每类 $n = 400$ 、 $\alpha = 0.01$ 的实验设计下, 本文能以约 80% 的把握排除大于 $2.4\text{--}3.5\ \mu\text{s}$ (视参数集而定) 的稳定时间差异; 量级更小的潜在差异不在本文方法的可分辨范围内。

5.6 特征重要性与运行稳定性

图 7 展示了 `single_bit` 策略下随机森林特征重要性在三个参数集之间的比较。各特征重要性整体较为分散, 没有出现单一特征在真实场景中稳定主导分类的现象。这与模型准确率接近随机的结果一致: 模型并未找到可泛化的泄漏方向。

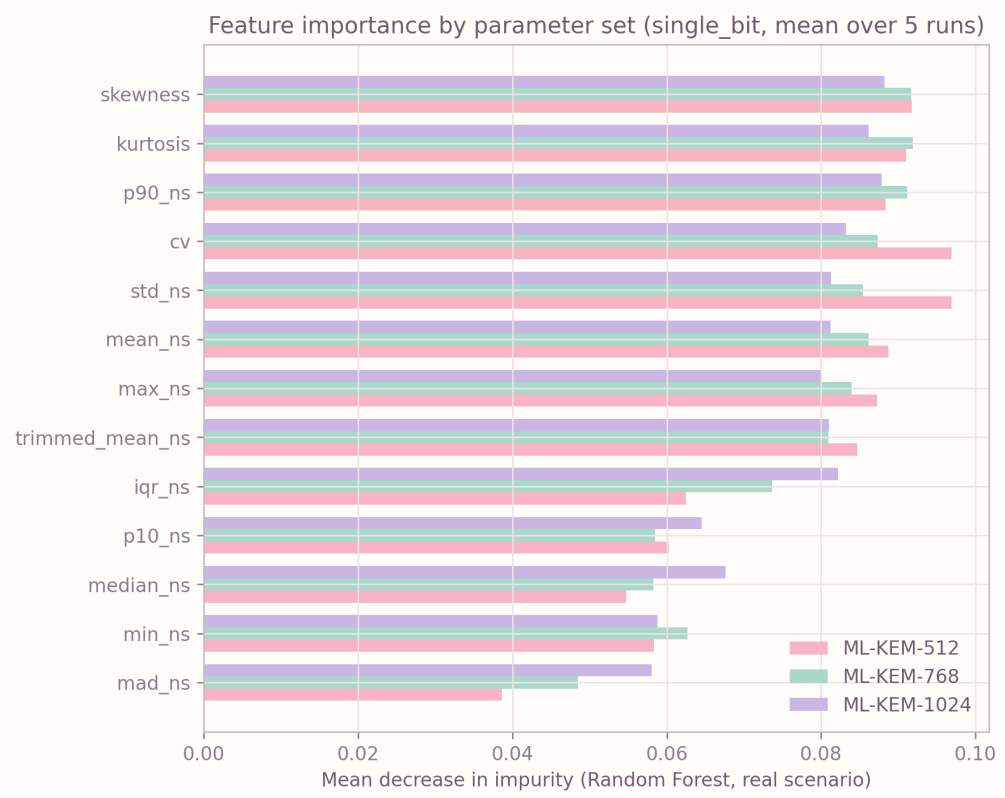


图 7: single_bit 策略下三个参数集的随机森林特征重要性。

图 8 给出 60 次实验的时间差稳定性。真实场景中的差异围绕 0 上下波动，没有持续同向偏移；正对照场景则保持在接近 20,000 ns 的正向差异附近，说明真实场景中的小幅波动更可能来自操作系统调度、缓存状态和测量噪声，而不是稳定输入相关信号。

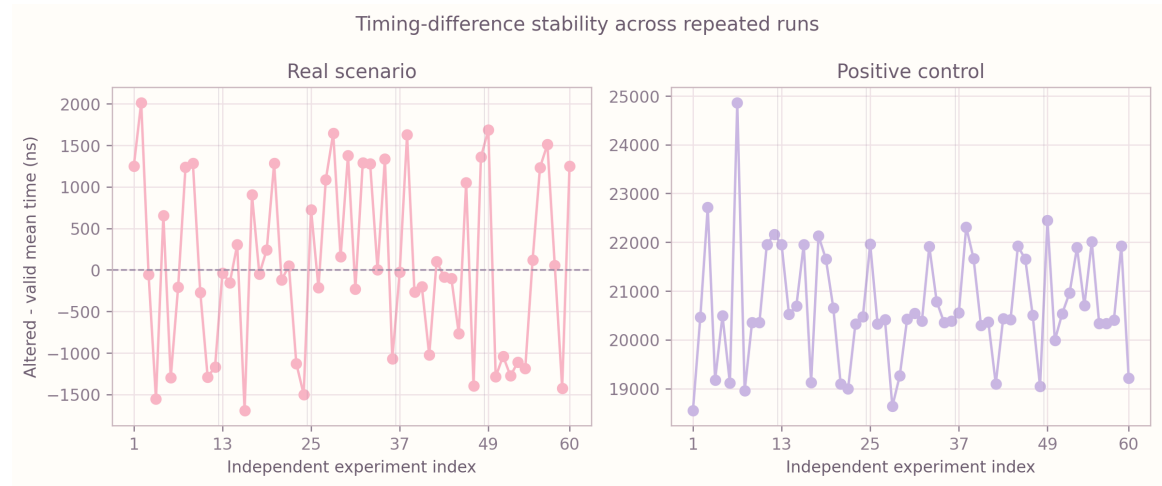


图 8: 60 次实验中真实场景与正对照场景的平均时间差稳定性。

6 讨论

6.1 结果解释

统计检验、效应量和机器学习结果共同支持同一结论：在本文设置下，未检测到 pqcrypto ML-KEM 解封装实现对有效密文和四类无效密文表现出稳定、可利用的时间差异。尤其需要注意的是，真实场景的最佳模型准确率最高单次仅 0.5566，虽偶有高于 0.5 的结果，但跨轮次、跨参数集和跨策略后均不稳定，也没有同时满足统计显著性与效应量阈值。正对照的高准确率说明这一负结果不能简单归因于检测程序失效。

从数据本身看，实验结果更像是噪声条件下的弱随机波动，而不是采集失败或明显泄漏。60 次真实场景中，仅 1 次最佳平衡准确率超过 0.55，且没有任何一次超过 0.60；Welch's t 检验只有 2 次低于 0.05，没有一次低于 0.01；Cohen's d 的绝对值最大为 0.1501，低于本文设定的小效应阈值 0.2。平均时间差的方向也不稳定，跨实验最小值为 -1691.5 ns，最大值为 2014.8 ns，说明单次均值差异容易受到操作系统调度和运行状态影响。与之相对，正对照最佳平衡准确率均值达到 0.9995，说明当时间信号足够强时，本文流程能够稳定识别。因此，本文结果应被表述为有边界的负检测结果，而不是算法或实现的形式化安全证明。

需要强调的是，本文的负检测结果并不意味着检测流程缺乏灵敏度。固定延迟正对照在全部实验中均能被稳定识别，延迟灵敏度扫描也显示，当人为延迟达到一定量级时，统计检验、效应量和机器学习分类会同时给出明确响应。因此，真实场景未触发泄漏判定，更合理的解释是在当前软件计时条件和输入模型下，被测实现没有表现出超过检测阈值的稳定时间差异。

ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 的平均解封装时间随参数增大而增加，single_bit 策略下有效密文 5 轮均值约为 28.25 μ s、41.96 μ s 和 60.12 μ s。但计算量增长并未带来更明显的有效/无效分类信号，说明在所测实现和输入模型下，参数集变化主要影响整体耗时，而不产生稳定标签相关差异。

6.2 实验局限性

本文结论具有明确边界。首先，软件计时在通用操作系统上不可避免地受到任务调度、动态频率、缓存状态和后台 I/O 的影响。聚合重复、预热和随机打乱只能降低噪声，不能等同于硬件实验台的隔离测量。其次，本文标签区分的是有效密文与无效密文，而不是私钥比特或秘密中间值；即便检测到差异，也仍需进一步分析其是否可转化为密钥恢复攻击。第三，实验对象限定为 pqcrypto==0.3.4 的具体绑定，不能直接推广至所有 ML-KEM 实现、所有编译器选项或所有处理器平台。最后，本文只测试四类无效密文模型，不能覆盖所有选择密文输入空间。

关于平台局限性，项目早期还在 macOS arm64 (Apple Silicon) 平台上对 ML-KEM-768 进行过 5 轮探索性实验，作为本文正式实验之外的补充观察。该探索性实验在方法学上与本文正式流水线存在差异：每类样本数为 240（而非 400）、每条聚合

轨迹重复 35 次（而非 50 次）、特征维度为 9 维（而非 13 维）、分类器仅包含线性 SVM 和随机森林两种（而非四种），且运行环境为 Python 3.9.6。在这一不同处理器架构和不同流水线参数下，5 轮真实场景结果同样均未触发泄漏判定（最佳模型平衡准确率 0.448–0.525，Welch’s t 检验 p 值介于 0.071–0.617 之间），而正对照在 5 轮中均能被稳定识别（平衡准确率均不低于 0.99，时间差均接近 20,000 ns）。表 8 列出了 5 轮的详细结果。该探索性结果在定性层面与本文 Windows x86_64 上的正式结论一致，但由于样本量、特征集和模型集均不同，不构成严格的跨平台对照实验，仅作为本文方法在 x86_64/arm64 与 Windows/macOS 之间定性可复现性的初步佐证；逐一参数集/策略组合的严格跨平台矩阵留作后续工作。

表 8: macOS arm64 探索性实验 (ML-KEM-768, 5 轮)

轮次	真实场景			正对照	
	最佳平衡准确率	Welch p	Cohen’s d	最佳平衡准确率	时间差 (ns)
1	0.525	0.071	-0.165	0.993	21355.2
2	0.511	0.173	0.125	1.000	20132.0
3	0.503	0.256	-0.104	1.000	20516.5
4	0.515	0.552	-0.054	1.000	20253.3
5	0.512	0.617	0.046	1.000	20555.7

此外，本文的观测粒度是端到端解封装耗时，而 KyberSlash 等工作揭示的密钥相关时序泄漏可能来自单条变长除法或压缩指令，其耗时差异在纳秒级总时间中可能被其他噪声源淹没 [4]。因此，本文的负结果不能说明被测实现在指令级别不存在此类问题，只能说明在端到端黑盒计时这一观测粒度下未发现稳定可区分信号；若要排查 KyberSlash 类问题，需要结合源码审计或指令级污点分析等更细粒度的方法。

6.3 可复现性与后续工作

项目保留了完整采集脚本、原始 CSV、JSON 分析报告、数据质量报告和论文图表。后续工作可以从三个方向展开：第一，在 Linux x86_64、macOS arm64 和不同 CPU 微架构上重复完整矩阵，比较平台差异；第二，使用更高重复次数或进程绑定、性能模式锁定等方法降低软件计时噪声；第三，将同样的输入模型扩展到功耗或电磁轨迹，比较软件时序与物理侧信道的灵敏度差异。

为支持独立复现，本文采集脚本、原始计时 CSV、统计与机器学习分析的 JSON 报告、数据质量报告以及生成本文全部图表的代码均随项目一并提供，具体目录结构和重新运行命令见附录。第三方可在安装相同版本依赖后，直接基于附录中的命令重新生成本文表 4–6 和图 2–8 中的全部结果。

7 结论

本文围绕 ML-KEM 解封装实现，建立了一套结合统计检验、机器学习分类和正对照验证的软件时间侧信道泄漏筛查框架。该框架能够从均值差异、分布差异、效应

量和多维特征可分性等多个角度评估有效密文与无效密文之间是否存在稳定时间信号。

实验覆盖 ML-KEM-512、ML-KEM-768 和 ML-KEM-1024 三个参数集，以及四类同长度无效密文策略。结果显示，60 次真实场景实验均未触发泄漏判定，最佳模型平衡准确率接近随机基线，Cohen's d 未达到小效应阈值，统计检验也未形成稳定显著模式。与此同时，固定延迟正对照能够被稳定识别，说明检测管线具备发现已知时间信号的能力。

因此，本文得出谨慎结论：在当前 Windows 11 x86_64 软件计时条件、pqcrypto 版本和本文测试的输入模型下，未检测到 ML-KEM 解封装实现对有效密文与无效密文表现出稳定、可区分的时间侧信道泄漏。该结论属于实现级筛查结论，不构成形式化侧信道安全证明，也不能替代跨平台实验、硬件性能计数器分析、功耗分析或电磁侧信道评估。

参考文献

- [1] Roberto Avanzi, Joppe Bos, Léo Ducas, Eike Kiltz, Tancrede Lepoint, Vadim Lyubashevsky, John M. Schanck, Peter Schwabe, Gregor Seiler, and Damien Stehlé. CRYSTALS-Kyber: Algorithm specifications and supporting documentation. In *NIST Post-Quantum Cryptography Standardization*, 2019.
- [2] Georg T. Becker, Justin Cooper, Elke DeMulder, Gilbert Goodwill, Joshua Jaffe, Gary Kenworthy, Tanya Kouzminov, Andrew Leiserson, Mark Marson, Pankaj Rohatgi, and Sami Saab. Test vector leakage assessment (TVLA) methodology in practice. In *International Cryptographic Module Conference*, 2013.
- [3] Daniel J. Bernstein. Cache-timing attacks on AES, 2005.
- [4] Daniel J. Bernstein, Karthikeyan Bhargavan, Shivam Bhasin, Anupam Chattopadhyay, Tee Kiah Chia, Matthias J. Kannwischer, Franziskus Kiefer, Thales B. Paiva, Prasanna Ravi, and Goutam Tamvada. KyberSlash: Exploiting secret-dependent division timings in Kyber implementations. *IACR Transactions on Cryptographic Hardware and Embedded Systems*, 2025(2):209–234, 2025.
- [5] Leo Breiman. Random forests. *Machine Learning*, 45(1):5–32, 2001.
- [6] David Brumley and Dan Boneh. Remote timing attacks are practical. *Computer Networks*, 48(5):701–716, 2005.
- [7] Eleonora Cagli, Cécile Dumas, and Emmanuel Prouff. Convolutional neural networks with data augmentation against jitter-based countermeasures. In *Cryptographic Hardware and Embedded Systems – CHES 2017*, volume 10529 of *Lecture Notes in Computer Science*, pages 45–68. Springer, 2017.
- [8] Tianqi Chen and Carlos Guestrin. XGBoost: A scalable tree boosting system. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 785–794, 2016.
- [9] Jacob Cohen. *Statistical Power Analysis for the Behavioral Sciences*. Lawrence Erlbaum Associates, 2nd edition, 1988.
- [10] Paul C. Kocher. Timing attacks on implementations of Diffie-Hellman, RSA, DSS, and other systems. In *Advances in Cryptology – CRYPTO 1996*, volume 1109 of *Lecture Notes in Computer Science*, pages 104–113. Springer, 1996.
- [11] Liran Lerman, Gianluca Bontempi, and Olivier Markowitch. Power analysis attack: An approach based on machine learning. *International Journal of Applied Cryptography*, 3(2):97–115, 2015.

- [12] Henry B. Mann and Donald R. Whitney. On a test of whether one of two random variables is stochastically larger than the other. *The Annals of Mathematical Statistics*, 18(1):50–60, 1947.
- [13] National Institute of Standards and Technology. Module-Lattice-Based Key-Encapsulation Mechanism Standard. Federal Information Processing Standard FIPS 203, U.S. Department of Commerce, Gaithersburg, MD, 2024.
- [14] Fabian Pedregosa, Gaël Varoquaux, Alexandre Gramfort, Vincent Michel, Bertrand Thirion, Olivier Grisel, Mathieu Blondel, Peter Prettenhofer, Ron Weiss, Vincent Dubourg, et al. Scikit-learn: Machine learning in Python. *Journal of Machine Learning Research*, 12:2825–2830, 2011.
- [15] Robert Primas, Peter Pessl, and Stefan Mangard. Single-trace side-channel attacks on masked lattice-based encryption. In *Cryptographic Hardware and Embedded Systems – CHES 2017*, volume 10529 of *Lecture Notes in Computer Science*, pages 513–533. Springer, 2017.
- [16] Prasanna Ravi, Sujoy Sinha Roy, Anupam Chattopadhyay, and Shivam Bhasin. Generic side-channel attacks on CCA-secure lattice-based PKE and KEM schemes. In *IACR Transactions on Cryptographic Hardware and Embedded Systems*, volume 2020, pages 307–335, 2020.
- [17] Peter W. Shor. Algorithms for quantum computation: Discrete logarithms and factoring. In *Proceedings 35th Annual Symposium on Foundations of Computer Science*, pages 124–134, 1994.
- [18] Rei Ueno, Keita Xagawa, Yutaro Tanaka, Akira Ito, Junko Takahashi, and Naofumi Homma. Curse of re-encryption: A generic power/em analysis on post-quantum KEMs. In *IACR Transactions on Cryptographic Hardware and Embedded Systems*, volume 2022, pages 296–322, 2022.
- [19] Bernard L. Welch. The generalization of ‘Student’s’ problem when several different population variances are involved. *Biometrika*, 34(1/2):28–35, 1947.

附录

实验复现命令

本文实验代码已保存在项目目录中。完整实验可在安装依赖后通过如下命令运行：

```
python -m pip install -r requirements.txt
python -m pip install -r requirements-dev.txt
python -m pip install -e .
export LOKY_MAX_CPU_COUNT=8
export MLKEM_PERMUTATIONS=200
bash scripts/run_paper_experiments.sh
```

若只需快速检查环境，可使用小规模冒烟测试：

```
RUNS=1 SAMPLES_PER_CLASS=20 REPETITIONS=5 N_GROUPS=5 \
VARIANTS="768" INVALID_STRATEGIES="single_bit" \
MLKEM_PERMUTATIONS=5 bash scripts/run_paper_experiments.sh
```

主要数据文件说明

表 9: 论文实验相关输出文件

路径	说明
results/paper_runs/	5 轮完整实验的原始 CSV 与 JSON 分析结果
results/paper_artifacts/	论文图表与数据质量报告
DATA_QUALITY_REPORT.md	标签平衡、缺失值、正对照有效性等检查结果
summary.json	每个参数集/策略组合的统计检验和模型结果

泄漏判定规则

本文采用保守的联合判定方式。真实场景只有在以下三个条件同时满足时，才报告检测到时间泄漏：最佳模型平衡准确率不低于 0.65；Welch’s t 检验 $p < 0.01$ ；Cohen’s d 的绝对值不低于 0.2。正对照要求最佳模型平衡准确率不低于 0.90，且 Welch’s t 检验 $p < 0.001$ 。这一规则用于避免单一统计量偶然显著导致误判。